



Bảo mật web và ứng dụng

Thông tin môn học



- **Môn học:** Bảo mật web và ứng dụng.
- **30 tiết** lý thuyết (**15 buổi – 2 tiết/buổi**)
- **Giảng viên lý thuyết:**
 - TS. Phạm Văn Hậu
 - Email: haupv@uit.edu.vn
 - ThS. Ngô Khánh Khoa
 - Email: khoank@uit.edu.vn
- **Kênh trao đổi thông tin:** courses.uit.edu.vn

Khảo sát kiến thức

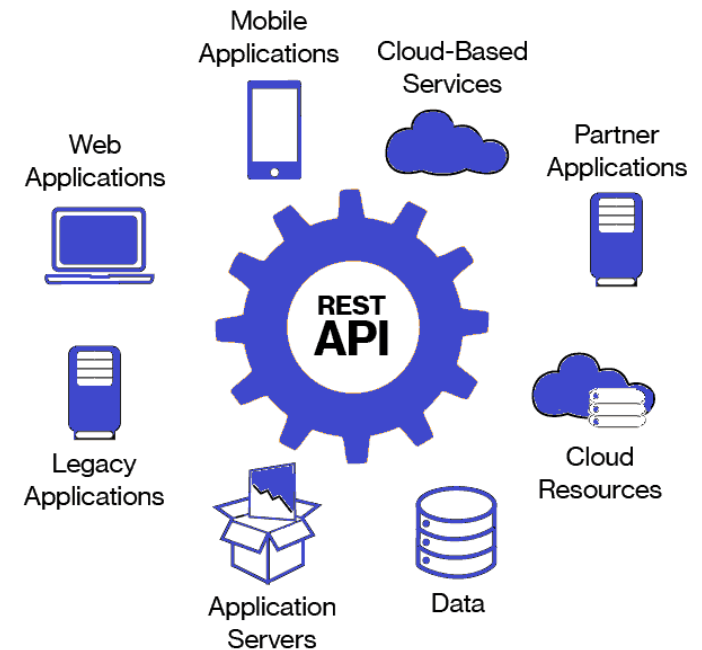


- Ứng dụng web
- Ứng dụng di động (Android/ iOS/...)
- Một số dạng tấn công vào các ứng dụng?
- CTF (Capture the Flag)?

Khảo sát kiến thức



Khảo sát kiến thức



Khảo sát kiến thức



OWASP

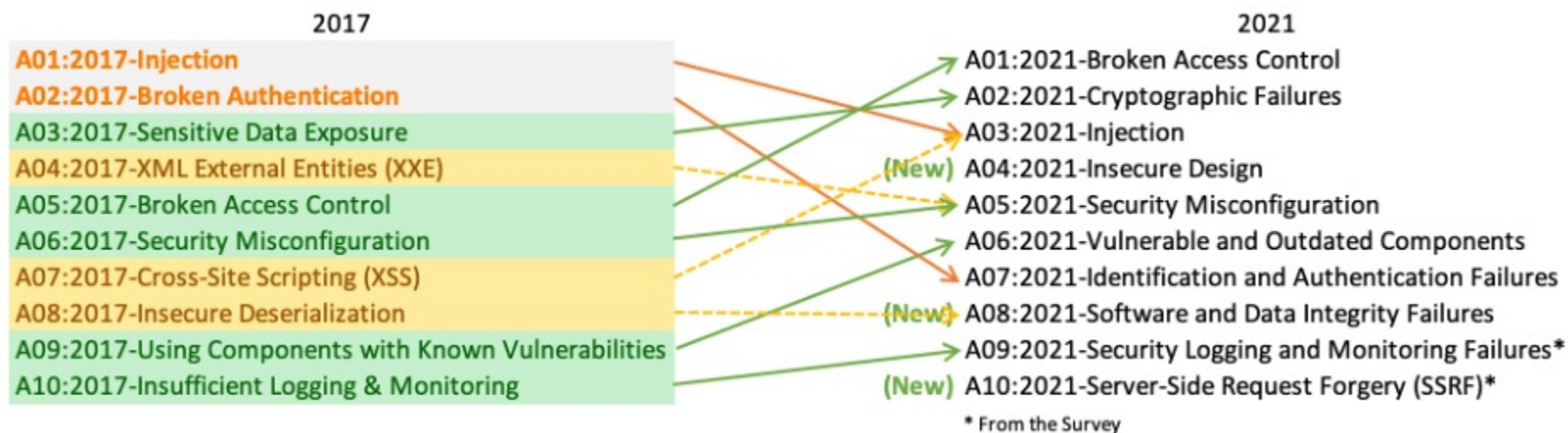
Open Web Application
Security Project



OWASP

Mobile Security Project

Khảo sát kiến thức



Mục tiêu và Nội dung



- **Mục tiêu:**

Trang bị những kiến thức cơ bản về bảo mật, bảo vệ dữ liệu và an toàn thông tin.

- **Nội dung:**

- Công cụ hỗ trợ tìm kiếm lỗ hổng, kiểm thử tự động
- Đảm bảo an toàn ứng dụng di động (Android/iOS)
- Kỹ thuật tấn công và thâm nhập ứng dụng web: XSS, CSRF, LFI, SQL Injection,...
- Một số giải pháp bảo vệ
- Checklist cho việc kiểm thử
- Cách viết báo cáo kiểm thử

Yêu cầu



- Lên lớp đúng giờ
- Tìm hiểu trước bài giảng
- Bài tập trên lớp + Đồ án môn học
- Làm nhóm:
 - Không ghi nhóm → sao chép
 - GV kiểm tra bất kỳ thành viên nào trong nhóm
- Sao chép bài → 0 (tất cả các nhóm giống nhau).
- Bất kì thành viên nào trong nhóm không nắm kiến thức của nội dung nhóm thực hiện → trừ điểm cả nhóm

Kế hoạch môn học dự kiến



Môn học

Bảo mật web và ứng dụng

Timeline môn học

Ngày bắt đầu		Sep 6, 2024																			
Tuần	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	Ghi chú
Bắt đầu	Sep 6	Sep 13	Sep 20	Sep 27	Oct 4	Oct 11	Oct 18	Oct 25	Nov 1	Nov 8	Nov 15	Nov 22	Nov 29	Dec 6	Dec 13	Dec 20	Dec 27	Jan 3	Jan 10	Jan 17	
Giới thiệu môn học																					
Kiến thức cơ bản																					
Top 10 OWASP																					
CSRF & XSS																					
SQLi																					
RLF, Command Inclusion																					
WAF																					
Anatomy of Mobile																					
Android Security (1)																					
Android Security (2)																					
Hacking phase, Pentest																					
Project	register																				

Đánh giá



- **30%** quá trình: đồ án, bài tập, điểm danh
- **30%** thực hành
- **40%** cuối kì

Chuẩn bị



Máy ảo:

- Kali Linux
- OWASP-BWA (OWASP Broken Web Apps)¹
- Windows 7²
- Khác: bWapp Bee-box³

¹: <https://sourceforge.net/projects/owaspbwa/files/>

²: <https://developer.microsoft.com/en-us/microsoft-edge/tools/vms/>

³: <https://www.vulnhub.com/entry/bwapp-beebox-v16,53/>

OWASP Broken Web Applications Project¹

- Máy ảo chứa nhiều ứng dụng web có nhiều lỗ hổng: PHP, Java, .Net, CMS (Joomla, Wordpress)
- Dành cho:
 - Học bảo mật ứng dụng web
 - Kiểm tra kỹ thuật đánh giá thủ công
 - Kiểm tra công cụ tự động
 - Kiểm tra công cụ phân tích mã nguồn
 - Quan sát tấn công web
 - Kiểm tra WAF và kỹ thuật tương tự

¹<https://sourceforge.net/projects/owaspbwa/files/>

- **Training applications:**
Hướng dẫn, giải thích,...
- **Realistic, intentionally vulnerable applications:**
Ứng dụng thực tế, lỗ hổng được mô phỏng
- **Old (vulnerable) versions of real application:**
Wordpress, Joomla

OWASP-BWA



- **Applications for testing tools:**

Cho việc thử nghiệm các công cụ scan tự động

- **Demonstration pages / small applications:**

Ứng dụng mẫu, minh họa

- **OWASP demonstration application:**

- OWASP AppSensor giả lập mạng xã hội và có nhiều lỗ hổng
- Log bất kỳ tấn công

OWASP-BWA



owaspbwa

OWASP Broken Web Applications Project

Version 1.2

This is the VM for the [Open Web Application Security Project \(OWASP\) Broken Web Applications](#) project. It contains many, very vulnerable web applications, which are listed below. More information about this project can be found in the project [User Guide](#) and [Home Page](#).

For details about the known vulnerabilities in these applications, see [https://sourceforge.net/p/owaspbwa/tickets/?limit=999&sort= severity+asc](https://sourceforge.net/p/owaspbwa/tickets/?limit=999&sort=severity+asc).



!!! This VM has many serious security issues. We strongly recommend that you run it only on the "host only" or "NAT" network in the virtual machine settings !!!

TRAINING APPLICATIONS

+ [OWASP WebGoat](#)

+ [OWASP WebGoat.NET](#)

+ [OWASP ESAPI Java SwingSet Interactive](#)

+ [OWASP Mutillidae II](#)

+ [OWASP RailsGoat](#)

+ [OWASP Bricks](#)

+ [OWASP Security Shepherd](#)

+ [Ghost](#)

+ [Magical Code Injection Rainbow](#)

+ [bWAPP](#)

+ [Damn Vulnerable Web Application](#)

Phần mềm máy ảo



Trình duyệt

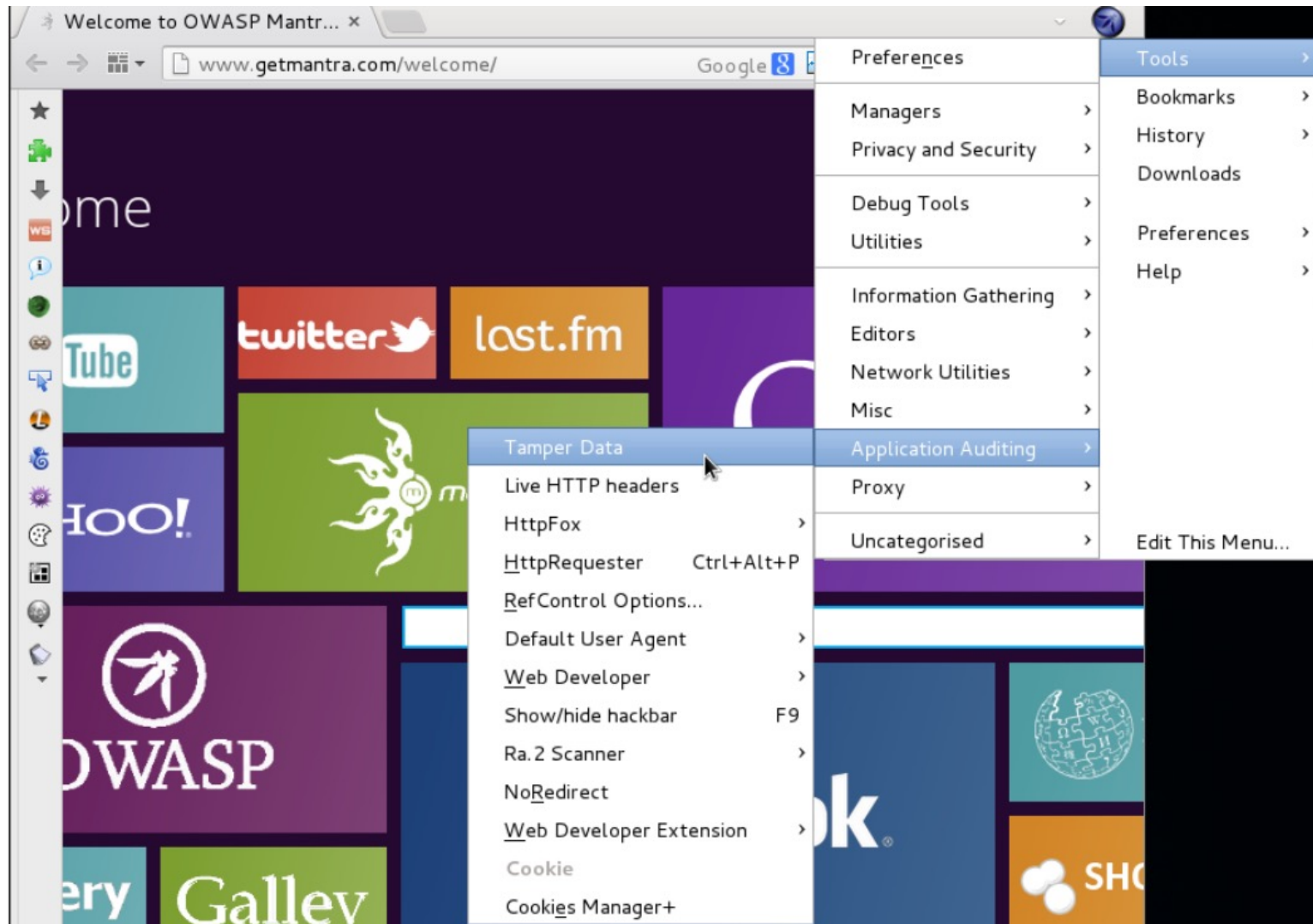


Hỗ trợ trên các trình duyệt



Function	 Google Chrome	 Mozilla Firefox	 Edge/IE	 Safari
Switching User Agents	✓	✓	✓	✓
Edit and Replay Requests	✗	✓	✗	✗
Editing Cookies	✓	✓	✓	✗
Editing Local Storage	✓	✓	✓	✗
Disable CSS	✓	✓	✓	✓
Disable Javascript	✓	✓	✗	✓
View Headers	✓	✓	✓	✓
Native screen-shot capture	✓	✓	✓	✗
Offline mode	✓	✓	✗	✗
Encode and Decode	✓	✓	✓	✓

Công cụ trên OWASP Mantra



Trình duyệt khác



- **Mantra** on Chromium (MoC): chỉ trên windows
- **Firefox** hoặc **Iceweasel** và add-on:
 - Tamper Data: bắt request, thay đổi data trước khi gửi
 - Cookies Manager+: xem và chỉnh sửa cookie
 - Firebug: in-line debugger
 - Hackbar: thay đổi input không cần thay đổi URL
 - HTTP Requester: thay đổi HTTP Request (GET, POST, PUT) và xem trả lời dạng raw
 - Passive Recon: lấy thông tin public: DNS query, Whois

Add-on hữu ích khác



- XSS Me
- SQL Inject Me
- **FoxyProxy**
- iMacros
- FirePHP
- **RESTClient**
- **Wappalyzer**

Tài liệu tham khảo

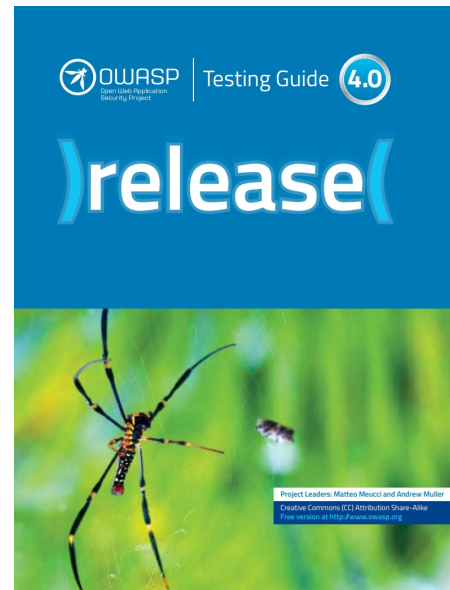
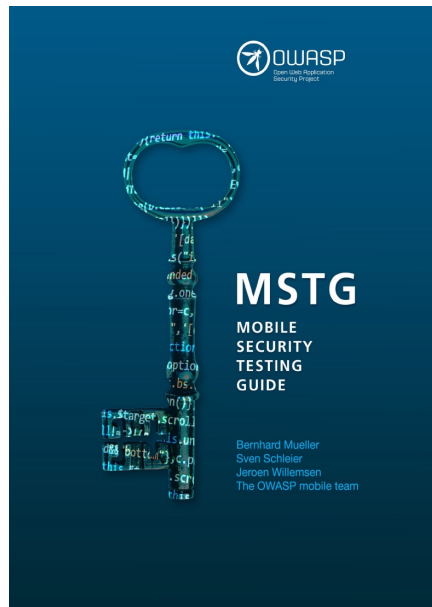


- Gilberto Najera-Gutierrez, **Kali Linux Web Penetration Testing Cookbook-Packt Publishing, 2016**
- Joseph Muniz - Aamir Lakhani, **Web Penetration Testing with Kali Linux, 2013**
- OWASP, **OWASP Web Application Security Quick Reference Guide 0.2, 2013**
- OWASP, **Mobile App Security Checklist 0.9.2, 2017**

Tài liệu tham khảo



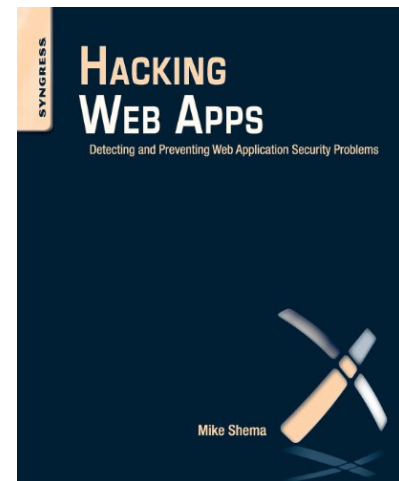
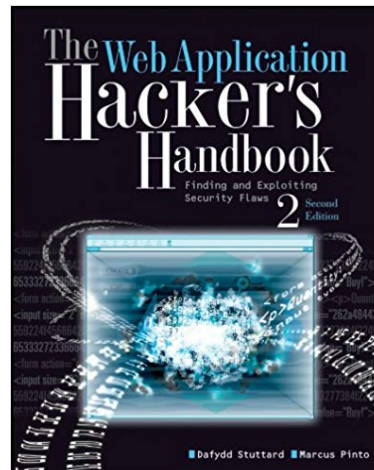
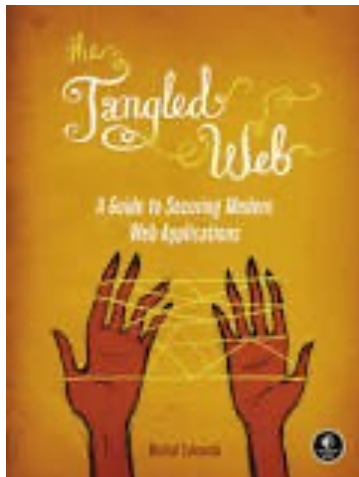
- OWASP, **OWASP Testing Guide** v4.0, 2014.
- OWASP Testing Guide v5 (2019).
Link: <https://github.com/OWASP/OWASP-Testing-Guide-v5>
- OWASP Mobile Security Testing Guide - 1.1.3 Release.
Link: <https://github.com/OWASP/owasp-mstg>



Tài liệu tham khảo



- **The Tangled Web: A Guide to Securing Modern Web Applications.** Michal Zalewski. No Start Press.
- **The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws.** Dafydd Stuttard. 2011.
- **Hacking Web Apps: Detecting and Preventing Web Application Security Problems.** Mike Shema. 2012

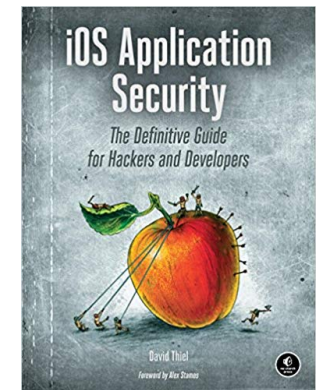
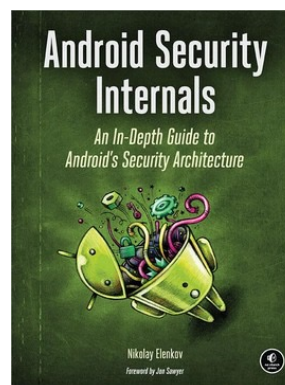


Tài liệu tham khảo



- **Application Security for the Android Platform: Processes, Permissions, and Other.** Jeff Six. 2011
- **ANDROID SECURITY: ATTACKS AND DEFENSES.** Abhishek Dubey, Anmol. 2013.
- **Android Security Internals : An In-Depth Guide to Android's Security Architecture.** Nikolay Elenkov. No Starch Press. 2015.
- **Android Application Secure Design/Secure Coding Guidebook**, 2018. Japan Smartphone Security Association (JSSEC)
- **iOS Application Security: The Definitive Guide for Hackers and Developers** 1st Edition. David Thiel. No Start Press. 2016.
- Mobile Security testing guide:

Link: <https://mobile-security.gitbook.io/mobile-security-testing-guide/>



Bảo mật web và ứng dụng



**Trường ĐH CNTT – ĐHQG
TP. HCM**